



SSO Configuration Check

SNYK Platform GovCloud

This report has been produced by TCS for DSG
Adversarial Testing

KPMG US

PPA - 920340

PTI - 920689

RP - 920356

SSO Configuration Check, Final

04/16/2026

This report is to assist with vulnerability remediation activities. This report does not carry an endorsement from the KPMG US Adversarial Testing Team.

This report is for KPMG INTERNAL USE ONLY and its content cannot be shared or distributed in any form with a third-party client or vendor without initiating the client inquiry process.

Contents

- Executive Summary 1
 - Background and Scope 1
 - Summary of Findings 1
 - Assessment Details 3
- Detailed Findings..... 4
- Appendix 33
 - Risk Rating Criteria 34
 - Terminology 35
 - Methodology 36
 - DSG Disclaimer Notice 37

Assessment Overview

Timeline

Assessment Start Date	04/13/2026
Assessment Completion Date	04/16/2026
Report Completion	04/16/2026

Team

Name	Role	Email
Pranshu Raghav	Tester	pranshuraghav@kpmg.com
Paramita Das	Reviewer	paramitadas@kpmg.com

Report History

Name	Company	Date	Description
Pranshu Raghav	TCS	04/16/2026	Initial Report

Executive Summary

Background and Scope

As part of the Digital Security Group's (DSG) Adversarial Testing Program, TCS conducted a dynamic automated or manual SSO configuration check for SNYK Platform GovCloud.

The TCS team performed time bound security testing through manual methods. TCS has leveraged Burp Suite for conducting manual tests along with other open-source security testing software. The purpose of this SSO configuration check on the application was to identify the potential vulnerabilities.

The manual assessment encompassed the modules of Information gathering, Configuration management, Authentication testing, Authorization testing, session management, Input validation, and encryption to identify the security issues which could potentially affect the application.

The TCS team identified a total of 15 findings which were categorized across various severity levels. No automated scans were performed for this SSO configuration check.

Summary of Findings

During this assessment, Fifteen (15) findings across all phases of testing were identified. Each finding has been classified into categories **Very High**, **High**, **Medium**, **Low**, and **Informational** (0 Very High, 0 High, 0 Medium, 5 Low, 10 Informational) based on the risk level.

The table below details the findings discovered during the assessment. Each finding has been assigned a risk rating based on its potential impact to the firm and the likelihood of exploitation. These ratings provide a baseline for prioritization but should be evaluated within the broader context of the organization's security posture and existing compensating controls. The results of this assessment represent a point-in-time analysis of the application's security.

#	Finding	Dependency	Prior Test	Likelihood	Impact	Original Risk Rating	Updated Risk Rating
1.	Missing Sub-Resource Integrity Check	Application	NA	Medium	Minor	Low	Low
2.	Improper CSP Header leads to XSS	Application	NA	Medium	Minor	Low	Low
3.	Okta PIV/Certificate Authentication Endpoint Active and Exposed	Application	NA	Medium	Minor	Low	Low
4.	DNS Certification Authority Authorization (CAA) Record Missing	Application	NA	Low	Low	Low	Low
5.	OCSP Stapling Not Enabled	Application	NA	Low	Low	Low	Low
6.	Improper Response Header	Microsoft	NA	Low	Low	Low	Informational

#	Finding	Dependency	Prior Test	Likelihood	Impact	Original Risk Rating	Updated Risk Rating
7.	Missing Security Response Headers	Microsoft	NA	Low	Low	Low	Informational
8.	SAML – Weak Canonicalization Method Used	Microsoft	NA	Low	Low	Low	Informational
9.	Sensitive Information in GET URL	Okta	NA	Very Low	Negligible	Informational	Informational
10	HSTS Not Submitted to Browser Preload Lists	Application	NA	Very Low	Negligible	Informational	Informational
11.	Sensitive Information Disclosure	Application / Okta / Microsoft	NA	Very Low	Negligible	Informational	Informational
12.	Internal/Hidden API Endpoints Exposed	Application	NA	Very Low	Negligible	Informational	Informational
13.	RSA 2048-bit Key — Plan Migration to Stronger Algorithm	Application	NA	Very Low	Negligible	Informational	Informational
14.	SSL Certificate Expiry in Approximately 4.5 Months	Application	NA	Very Low	Negligible	Informational	Informational
15.	Concurrent User Session	Okta	NA	Low	Negligible	Informational	Informational

Notes: NA.

Limitations: NA

Disclaimer: This report contains examples of instances where certain vulnerabilities have been identified. However, the issue may not be only limited to the instances reported. We certainly advise that a global fix be implemented to remediate all vulnerabilities and not limit the remediation to just the instances identified in this report

Assessment Details

In addition to the findings summarized above, several assessment parameters provide context for the scope and configuration of the test. These details outline the environment, roles, and conditions under which the application was evaluated and should be considered when reviewing the overall results. The table below captures the key inputs and constraints of the assessment.

Field	Details
Test URL	https://app.snykgov.io
Testing Environment	Dev
Number of Access Level in Scope	NA
User Roles	pranshuraghav@kpmg.com user1testad1@dev.uskgc.com user3testad3@dev.uskgc.com
Scope of Test	SSO
Testing Window	04/13/2026 to 04/16/2026
Point of Contact (App Team)	Solomon, Abigail

Detailed Findings

Finding 1: Missing Sub-Resource Integrity Check
Low
Dependency: Application Status: Open Description: Testing identified that the Snyk login and post-authentication pages load JavaScript from third-party domains with full DOM access during the authentication flow: FullStory (edge.fullstory.com) — Session recording, Org ID: RX2JA Sentry (js.sentry-cdn.com) — Error monitoring Segment (segment.com) — Analytics FullStory actively records session data, confirmed by POST requests to rs.fullstory.com/rec/page during the authentication flow. These scripts execute in the same origin as the auth pages and can access DOM content including SSO parameters. Affected Systems & Locations: https://app.snykgov.io/login https://app.snykgov.io/auth/okta/callback Reproduction Steps: 1. Navigate to app.snykgov.io/login with Burp proxy active. 2. Observe requests to edge.fullstory.com/s/fs.js and js.sentry-cdn.com loaded on the page. 3. Observe POST to rs.fullstory.com/rec/page confirming active session recording. 4. It is observed that Subresource Integrity Hashes are missing on the third-party js links in the response Screenshots:

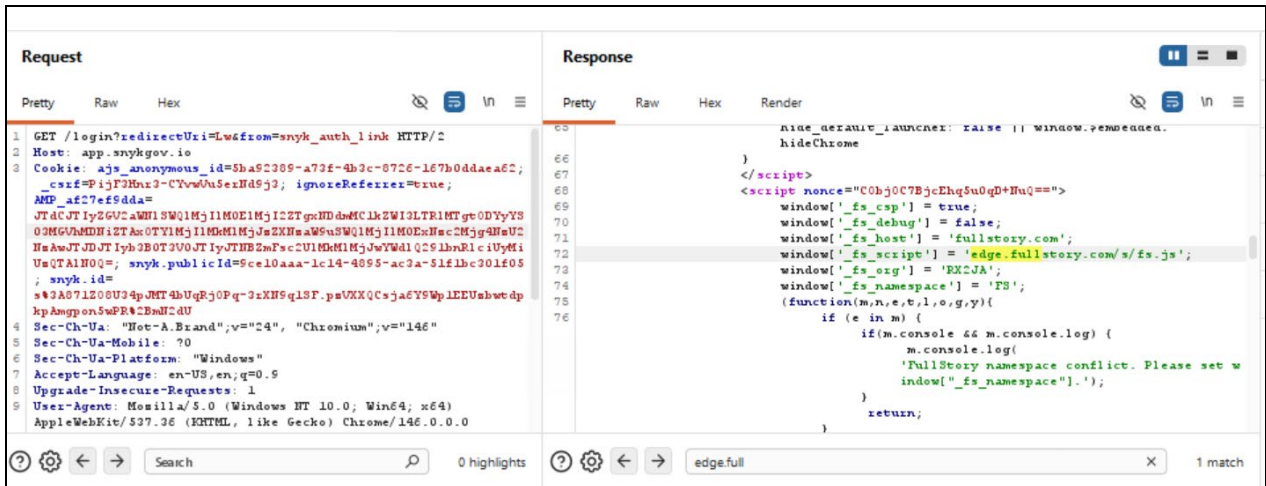


Figure1

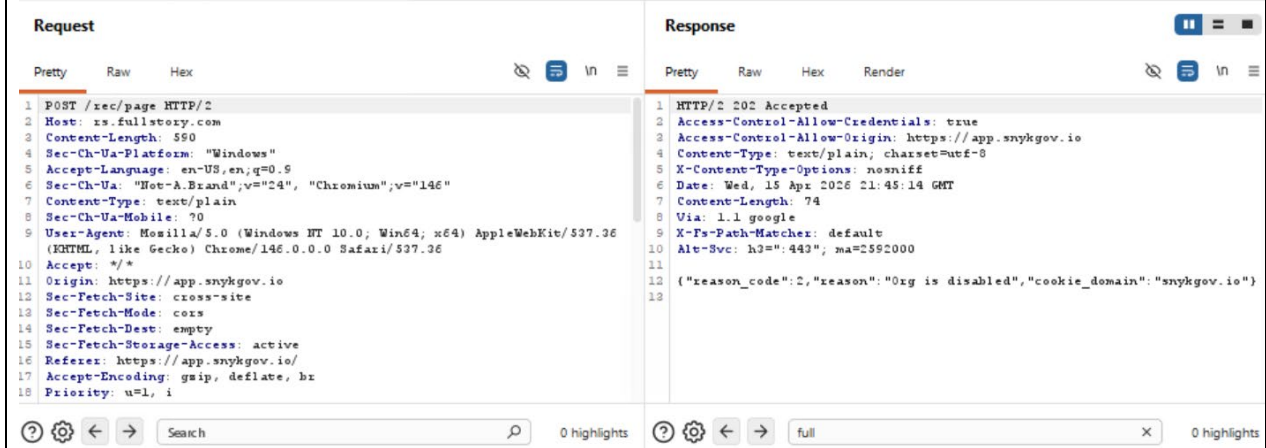


Figure2

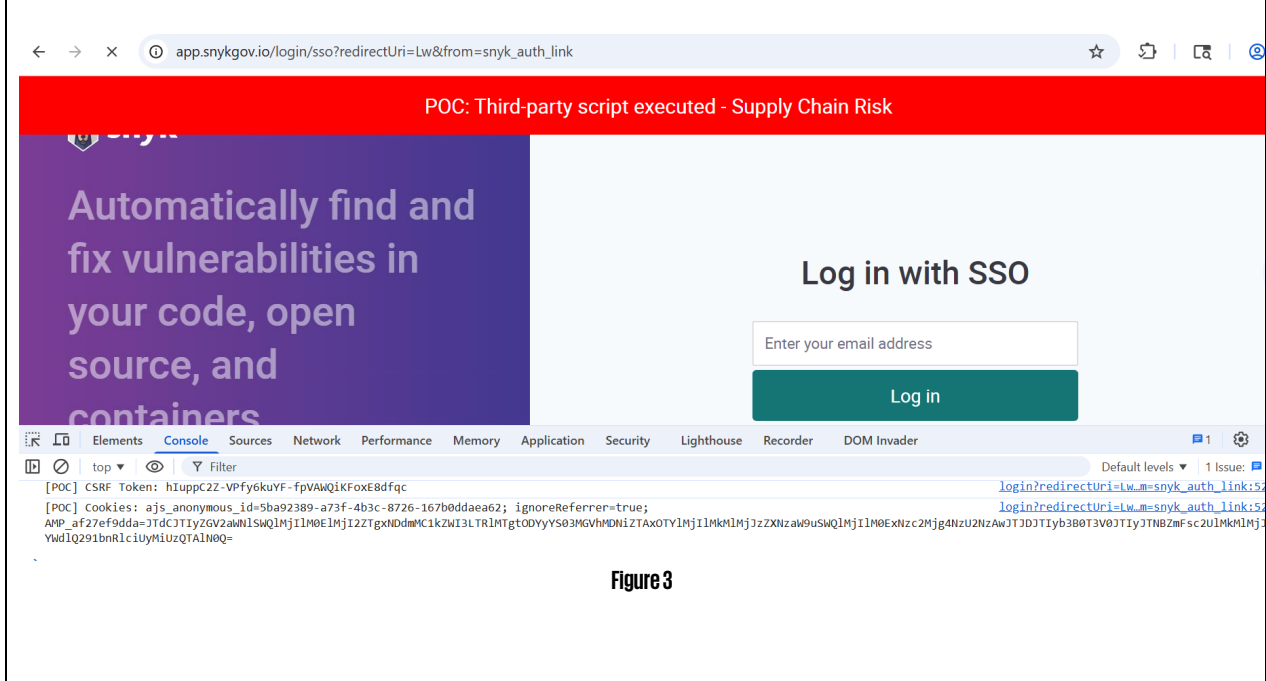


Figure3

Remediation:

Exclude authentication pages (/login, /auth/*) from FullStory session recording.

- Implement Subresource Integrity (SRI) hashes for all third-party scripts.
- Review FedRAMP SSP for third-party data handling obligations on authentication flows.

Closing/Downgrading Justification:

Finding 2: Improper CSP Header leads to XSS

Low

Dependency: Application

Status: Open

Description:

Testing identified that the Content-Security-Policy header includes 'unsafe-inline' and 'unsafe-eval' in the script-src directive:

script-src 'self' 'nonce-7YyCILYpQ3Q/Z/U6zvTCAg==' 'unsafe-inline' 'unsafe-eval' 'strict-dynamic' 'report-sample'

While CSP Level 3 browsers ignore unsafe-inline when a nonce is present, CSP Level 2 browsers honor it. The Permissions-Policy header is also not present. Other security headers (HSTS, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, Cache-Control) are correctly configured.

Affected Systems & Locations:

<https://app.snykgov.io>

Reproduction Steps:

1. Send a request to app.snykgov.io using Burp Suite.
2. Observe the Content-Security-Policy response header.
3. Confirm 'unsafe-inline' and 'unsafe-eval' are present in the script-src directive.
4. Confirm Permissions-Policy header is absent.

Screenshots:

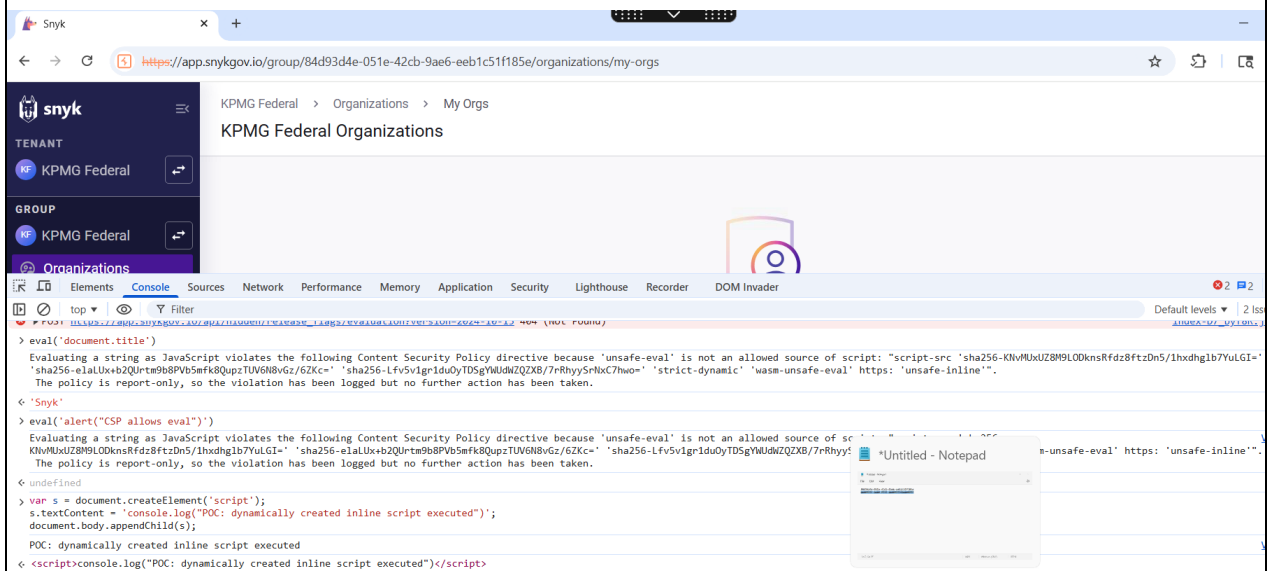


Figure 1

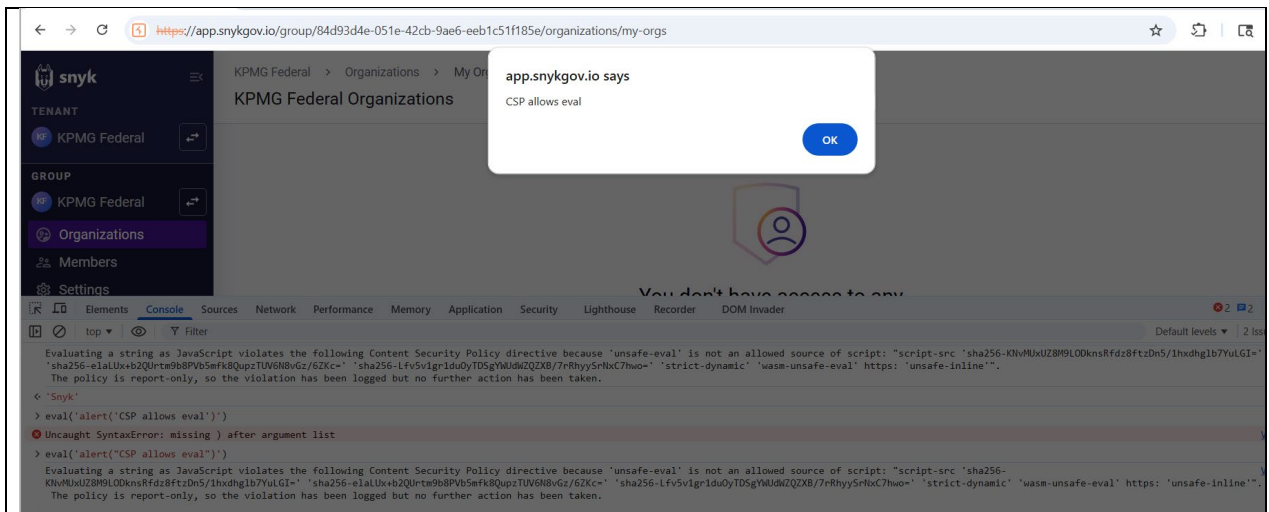


Figure 2

Remediation:

Remove 'unsafe-inline' and 'unsafe-eval' from CSP script-src.

- Rely on nonce-based loading with 'strict-dynamic'.
- Add a Permissions-Policy header.
- Remove deprecated X-XSS-Protection: 1; mode=block header.

Closing/Downgrading Justification:

Finding 3: Okta PIV/Certificate Authentication Endpoint Active and Exposed

Low

Dependency: Application

Status: Open

Description:

Testing identified that the Okta certificate authentication endpoint (/login/cert) is fully active and returns a functional PIV Card authentication page when accessed directly.

A POST request to /login/cert with the fromURI parameter returns HTTP 200 with a complete certificate authentication page titled "snyk-fedramp - Certificate authentication". The page reveals:

1. PIV Card / Smart card authentication is enabled and functional on the Okta org
2. The mutual TLS (mTLS) endpoint is disclosed: <https://snyk-fedramp.mtls.okta.com/auth/cert/primaryAuth>
3. The form auto-submits after 100ms via JavaScript (setTimeout form.submit, 100) — no user interaction required
4. Internal configuration parameters are exposed: isMobileClientLogin=false, isCustomDomain=false, rememberDevice=false, serverStatus=ACTIVE
5. The SAML relay endpoint is confirmed: fromURI points to snyk-fedramp.okta.com/sso/saml2/0oakdrgjz57kTklbU4h7

This represents an alternative authentication path that bypasses the standard Microsoft SSO + MFA chain. An attacker with a stolen or cloned PIV card could authenticate directly via this endpoint without going through the Microsoft identity provider.

Affected Systems & Locations:

<https://snyk-fedramp.okta.com/login/cert>
<https://snyk-fedramp.mtls.okta.com/auth/cert/primaryAuth>

Reproduction Steps:

1. In Burp Repeater, send: POST /login/cert to snyk-fedramp.okta.com with body fromURI=<https://snyk-fedramp.okta.com/sso/saml2/0oakdrgjz57kTklbU4h7>.
2. Observe HTTP 200 response with full PIV Card authentication page.
3. Note the page title: "snyk-fedramp - Certificate authentication".
4. Note the form action pointing to: <https://snyk-fedramp.mtls.okta.com/auth/cert/primaryAuth> (mTLS endpoint disclosed).
5. Note the auto-submit JavaScript: setTimeout(function(){ form.submit(); }, 100) — form submits without user interaction
6. Note the repost parameters exposing internal config: isMobileClientLogin, isCustomDomain, rememberDevice.
7. Note the Okta org config: serverStatus=ACTIVE, isPreview=false (confirms production environment).

Screenshots:

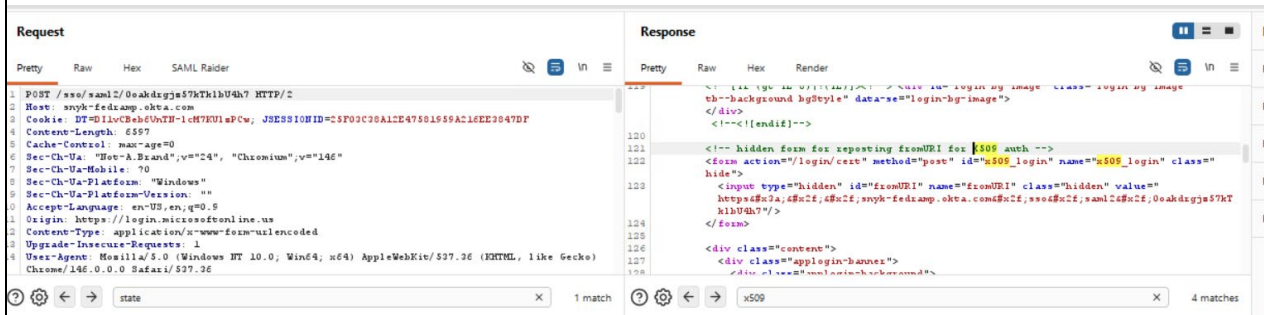


Figure1

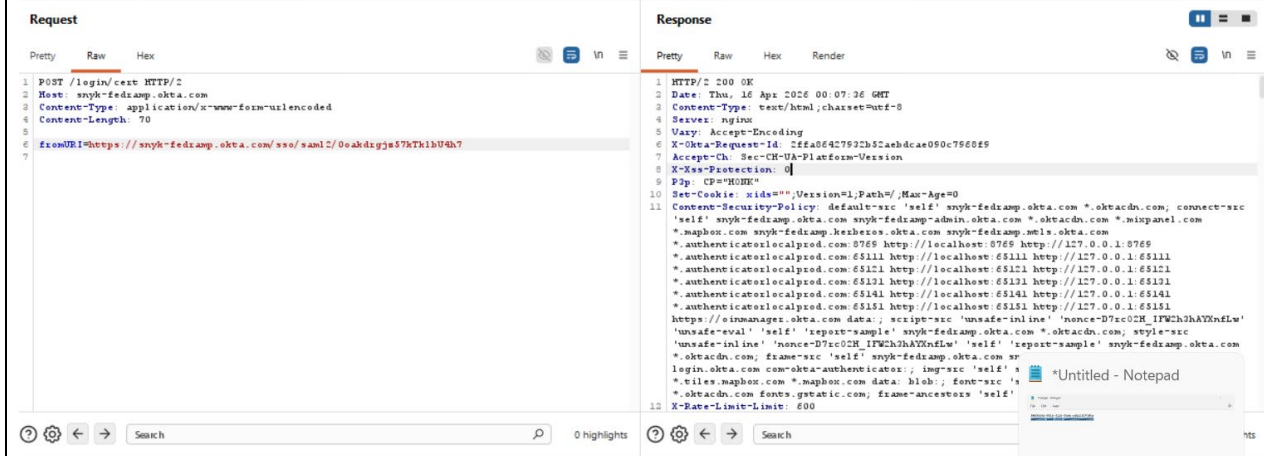


Figure2

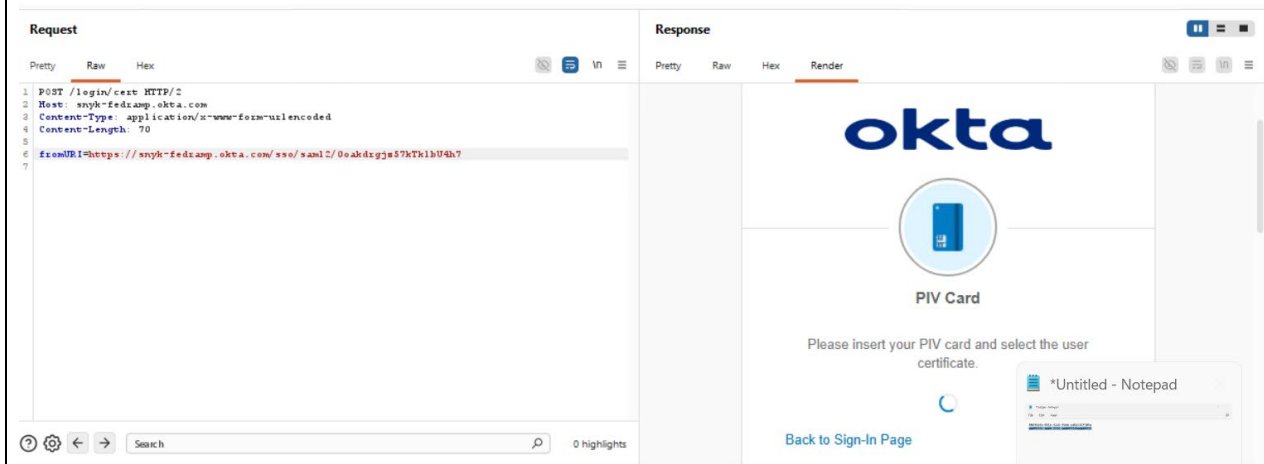


Figure3

Remediation:

If PIV/certificate authentication is not required for Snyk SSO, disable it in the Okta application routing rules.

- If PIV auth IS required, restrict access to /login/cert to only users with valid client certificates at the network level.

- Remove or gate the auto-submit behavior — add user confirmation before form submission.
- Suppress internal configuration parameters (isMobileClientLogin, isCustomDomain, rememberDevice, serverStatus) from the response body.
- Consider restricting direct access to the mTLS endpoint (snyk-fedramp.mtls.okta.com) to authorized network ranges only.

Closing/Downgrading Justification:

Finding 4: DNS Certification Authority Authorization (CAA) Record Missing

Low

Dependency: Application

Status: Open

Description:

The domain snykgov.io does not have a DNS Certification Authority Authorization (CAA) record configured. A CAA record instructs compliant Certificate Authorities (CAs) which organizations are authorized to issue TLS certificates for the domain. Without this control, any publicly trusted CA could technically issue a certificate for snykgov.io, increasing the risk of fraudulent or erroneous certificate issuance.

Affected Systems & Locations:

app.snykgov.io

Reproduction Steps:

1. Query the current DNS records: dig CAA snykgov.io
2. Confirm no CAA record is returned in the ANSWER section

Remediation:

- Add a DNS CAA record permitting only Amazon's CA to issue certificates: snykgov.io. CAA 0 issue "amazontrust.com"
- Add a corresponding issuewild entry for wildcard certificates: snykgov.io. CAA 0 issuewild amazontrust.com"
- Optionally configure an iodef entry to receive notifications of unauthorised issuance attempts.
- Verify the record is visible via public DNS resolvers after propagation.

Closing/Downgrading Justification:

Finding 5: OCSP Stapling Not Enabled

Low

Dependency: Application

Status: Open

Description:

Online Certificate Status Protocol (OCSP) stapling is not enabled on the server. Without OCSP stapling, connecting clients must perform a separate real-time lookup to the CA's OCSP responder (ocsp.r2m02.amazontrust.com) during each TLS handshake to verify certificate revocation status.

This introduces two concerns: (1) a minor latency penalty for each new connection as the client waits for the OCSP response from Amazon's infrastructure, and (2) a privacy implication — the CA's OCSP responder receives metadata about client connection activity. OCSP stapling moves this check server-side, catching the signed OCSP response and serving it during the TLS handshake, eliminating both concerns.

Affected Systems & Locations:

app.snykgov.io

Reproduction Steps:

1. Perform the Qualys Scan and look for OCSP stapling as NO.

Screenshot

Issuer	AMAZON R2M02 CERT AUTH AIA: http://crl.r2m02.amazontrust.com/r2m02.cer
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	Yes (certificate)
OCSP Must Staple	No
Revocation information	CRL, OCSP CRL: http://crl.r2m02.amazontrust.com/r2m02.crl OCSP: http://ocsp.r2m02.amazontrust.com
Revocation status	Good (not revoked)

Figure 1

Remediation:

- Enable OCSP stapling in the server's TLS configuration (e.g., `ssl_stapling on`; `ssl_stapling_verify on`; in nginx, or `SSLUseStapling On` in Apache).
- Configure a trusted OCSP responder cache: `ssl_trusted_certificate /path/to/chain.pem`; (nginx).
- Verify stapling is active post-configuration using the OpenSSL command above.
- Ensure the OCSP responder URL (ocsp.r2m02.amazontrust.com) is reachable from the server's

outbound network.

Closing/Downgrading Justification:

Finding 6: Improper Response Header

Low

Dependency: Microsoft

Status: Open

Description:

Testing identified that the Microsoft Entra ID GovCloud SAML login endpoint returns the deprecated X-XSS-Protection: 0 response header. This header was originally introduced by Internet Explorer to enable the browser's built-in XSS filter. Setting it to 0 explicitly disables that filter.

The X-XSS-Protection header has been deprecated and removed from all modern browsers (Chrome, Firefox, Edge). Its presence — even set to 0 — is considered a misconfiguration indicator for two reasons:

1. It indicates a legacy header policy is still active on the Microsoft platform, suggesting the header security configuration has not been fully modernized.

2. The value of 0 (disabled) provides no compensating protection and may cause older browsers that still parse this header to disable their built-in XSS filtering entirely on this page.

The correct modern posture is to remove this header entirely and rely on a properly configured Content-Security-Policy (CSP) for XSS protection — which is also currently absent from this endpoint (see Finding 15).

Note: The original severity of the finding is Low. However, it is being rated as Informational in this report. The finding is tracked in PPA-332020

Affected Systems & Locations:

<https://login.microsoftonline.us/f9724c3f-5875-41b3-b99a-b6eee358ee32/saml2>

Reproduction Steps:

1. Configure Burp Suite to intercept all SSO traffic and complete a full login flow to app.snykgov.io.
2. In Burp HTTP History, locate the POST request to:
login.microsoftonline.us/f9724c3f-5875-41b3-b99a-b6eee358ee32/saml2
3. Click the Response tab
4. It is observed that X-XSS header is set to 0.

Screenshot:

Host	Method	URL	Params	Status code ^	Length	MIME type	Title	Notes	Time req
https://login.microsoft...	POST	/f9724c3f-5875-41b3-b99...	✓	200	28266	HTML	Redirecting		19:26:28

Request

Response

Pretty

Raw

Hex

Render

```

1 HTTP/1.1 200 OK
2 Cache-Control: no-store, no-cache
3 Pragma: no-cache
4 Content-Type: text/html; charset=utf-8
5 Expires: -1
6 Vary: Accept-Encoding
7 Strict-Transport-Security: max-age=31536000; includeSubDomains
8 X-Content-Type-Options: nosniff
9 P3P: CP="DSP CUR OTPi IND OTRi ONL FIN"
10 x-ms-request-id: bc8b2182-89d0-4ec7-a161-478dbec71d00
11 x-ms-ests-server: 2.1.23906.2 - USGTX ProdSlices
12 Referrer-Policy: strict-origin-when-cross-origin
13 X-XSS-Protection: 0
14 Set-Cookie: esctx=Bq0iNeQsXIIs=
    AQABCQEAAgCYdzC7v2ADTbkbLuYoCIDfRXZvU3RzQXJ0aWZhY3RzDQAAAAAAncFZ-hRTUVS8XsSuTTx5dqEaXVFleu3y2pSAKWVNBjQEjebhsj-D3rc5kke95mD5cSwJeiYw7
    hBylSNqoS64q_1j9muinvIQoZxvi0fiUZyug8w5AgLiGqac8J_00ZMGXw86dJWHO0QParIS7fB9CAA; domain=.login.microsoftonline.us; path=/; secure;
    HttpOnly; SameSite=None
15 Set-Cookie: fpc=AoVqANYQwFhBoeRG6LeYfs0; expires=Sat, 16-May-2026 13:56:28 GMT; path=/; secure; HttpOnly; SameSite=None
16 Set-Cookie: esctx=
    PAQABBvEAAgCYdzC7v2ADTbkbLuYoCIDfRXZvU3RzQXJ0aWZhY3RzDQAAAAAALYM_vN6e6T-msUVLZYcx5gq4dzc063EctHjm_YajEdDBaXMJZ3ILTSt0a5F7ANsrKWcsFhFr
    OaFDrFT0f5UCwrsDz06_D6_xPhc91-HLVmkKPlg8nsbxxuZHwug8DzJLrp7-SKUvgFhrjEigN2g_nRsEG4KITB0rn-HRKEGN2a3wgAA;
    domain=.login.microsoftonline.us; path=/; secure; HttpOnly; SameSite=None
17 Set-Cookie: x-ms-gateway-slice=estsfd; path=/; secure; samesite=none; httponly
18 Set-Cookie: stsservicecookie=estsfd; path=/; secure; samesite=none; httponly

```

Finding 7: Missing Security Response Headers

Informational

Dependency: Microsoft

Status: Open

Description:

Testing identified that the Microsoft Entra ID GovCloud SAML login endpoint (login.microsoftonline.us) is missing several security response headers that are recommended by OWASP and expected in FedRAMP environments. These headers provide browser-level security controls that reduce the attack surface for cross-site scripting (XSS), clickjacking, and cross-origin data leakage.

Note: The original severity of the finding is Low. However, it is being rated as Informational in this report. The finding is tracked in PPA-332020

Affected Systems & Locations:

<https://login.microsoftonline.us/f9724c3f-5875-41b3-b99a-b6eee358ee32/saml2>

Reproduction Steps:

1. Configure Burp Suite to intercept SSO traffic and complete a full login flow to app.snykgov.io.
2. In Burp HTTP History, locate the POST request to login.microsoftonline.us/f9724c3f-5875-41b3-b99a-b6eee358ee32/saml2.
3. Click the Response tab and navigate to the Headers view.
4. Confirm the absence of Content-Security-Policy, X-Frame-Options, headers.

Screenshot:

Host	Method	URL	Params	Status code ^	Length	MIME type	Title	Notes	Time
https://login.microsof...	POST	/f9724c3f-5875-41b3-b99...	✓	200	28266	HTML	Redirecting		15
Request Response									
Pretty Raw Hex Render									
<pre>1 HTTP/1.1 200 OK 2 Cache-Control: no-store, no-cache 3 Pragma: no-cache 4 Content-Type: text/html; charset=utf-8 5 Expires: -1 6 Vary: Accept-Encoding 7 Strict-Transport-Security: max-age=31536000; includeSubDomains 8 X-Content-Type-Options: nosniff 9 P3P: CP="DSP CUR OTPi IND OTRi ONL FIN" 10 x-ms-request-id: bc8b2182-89d0-4ec7-al61-478dbec71d00 11 x-ms-ests-server: 2.1.23906.2 - USGTX ProdSlices 12 Referrer-Policy: strict-origin-when-cross-origin 13 X-XSS-Protection: 0 14 Set-Cookie: esctx=Bq0iNeqsXIs= AQABCEAAgCYdsC7vCADTbkbLuYoCIDfRXZvU3RzQXJOaWZhY3RzDQAAAAAAncFZ-hRTUV8BXeSuTTx5dqEaXVFleu3yCpSAKWVNBjQEjebhsj-D3rc5kke95md5cSwJes hBylSNqoS64q_lj5muinvIQoZxvi0fiUZYug8w5AgLiGqac8J_Q0ZMGXw86dJWH00QFuri57fB9CAA; domain=.login.microsoftonline.us; path=/; secure; HttpOnly; SameSite=None 15 Set-Cookie: fpc=AoVqANYQwFhBoeRG6LeYfs0; expires=Sat, 16-May-2026 13:56:28 GMT; path=/; secure; HttpOnly; SameSite=None 16 Set-Cookie: esctx= PAQABBBvEAAgCYdsC7vCADTbkbLuYoCIDfRXZvU3RzQXJOaWZhY3RzDQAAAAAALYM_vNge6T-msUVLZYcx5gq4dzc063EctHjm_YajEdDBaXQJZ3ILTSt0a5F7ANsrKWcs OaFDrFT0f5UCwrsDz06_D6_xPhc91-HLVmkKPlg8nsbxxuZHwug8DzJLrp7-SKUvgFhrjEigN2g_nRsEG4KITB0rn-HRUCN2a3wgAA; domain=.login.microsoftonline.us; path=/; secure; HttpOnly; SameSite=None 17 Set-Cookie: x-ms-gateway-slice=estsfd; path=/; secure; samesite=none; httponly 18 Set-Cookie: sts-service-cookie=estsfd; path=/; secure; samesite=none; httponly</pre>									

Figure 1

Remediation:

Enable X-FRAME-OPTIONS protection. X-Frame-Options Header Types

There are three possible values for the X-Frame-Options headers:

DENY, which prevents any domain from framing the content.

SAMEORIGIN, which only allows the current site to frame the content.

ALLOW-FROM uri, which permits the specified 'uri' to frame this page (NOTE: Not all browsers support this option).

It is recommended to implement a Content Security Policy header to restrict the sources from which the browser can load resources. The policy should be tailored to the application's legitimate resource requirements.

Closing/Downgrading Justification:

Finding 8: SAML - Weak Canonicalization Method Used

Informational

Dependency: Microsoft

Status: Open

Description:

Testing included a review of the XML canonicalization algorithm used within SAML assertions issued by Microsoft Entra ID during the SSO authentication flow. Canonicalization in SAML refers to the process of converting an XML document to a standard form before computing its digital signature — the choice of algorithm directly determines resistance to XML Signature Wrapping (XSW) attacks.

SAML Element	Value Observed
CanonicalizationMethod	http://www.w3.org/2001/10/xml-exc-c14n#WithComments
SignatureMethod	http://www.w3.org/2001/04/xmldsig-more#rsa-sha256
Transform Algorithm	http://www.w3.org/2000/09/xmldsig#enveloped-signature
Transform Algorithm (C14N)	http://www.w3.org/2001/10/xml-exc-c14n#WithComments
DigestMethod	http://www.w3.org/2001/04/xmlenc#sha256

Note: The original severity of the finding is Low. However, it is being rated as Informational in this report. The finding is tracked in PPA-332020

Affected Systems & Locations:

<https://login.microsoftonline.us/f9724c3f-5875-41b3-b99a-b6eee358ee32/saml2>

Reproduction Steps:

1. Configure Burp Suite to intercept all SSO traffic and complete a full login flow to app.snykgov.io.
2. In Burp HTTP History, locate the POST to login.microsoftonline.us returning HTTP 200 Click the Response tab and navigate to the Headers view.
3. Click the Response tab → Inspector panel → JSON Web Token tab.
4. In the Inspector panel on the right, locate the ds:CanonicalizationMethod element.
5. Confirm the Algorithm attribute reads: <http://www.w3.org/2001/10/xml-exc-c14n#WithComments> (highlighted in yellow in Figure 1).

Screenshot:

Finding 9: Sensitive Information in GET URL

Informational

Dependency: Okta

Status: Open

Description:

Testing identified that the SSO authentication flow transmits sensitive authentication tokens as query string parameters in GET request URLs. Information passed in URL query strings is logged in browser history, web server access logs, proxy logs, and is susceptible to shoulder surfing.

Tokens observed in URLs:

1. Okta stateToken: GET

/login/token/redirect?stateToken=02H0Z4JikLJH5egJDI5Ayh6V_qn7XPFR8j1S8mWBtc (5x)

2. stateTokenExternalId: GET /sso/idps/0oakdrgjz57kTklbU4h7?stateTokenExternalId=RUCzL0I4dEpx... (11x)

3. OAuth authorization code: GET /auth/okta/callback?code=kCa4o_nClju5SeSkGAkLWw... (4x)

Mitigating factor: Referrer-Policy: strict-origin-when-cross-origin is correctly set, preventing token leakage to third-party domains via Referer headers.

Affected Systems & Locations:

<https://snyk-fedramp.okta.com/login/token/redirect>

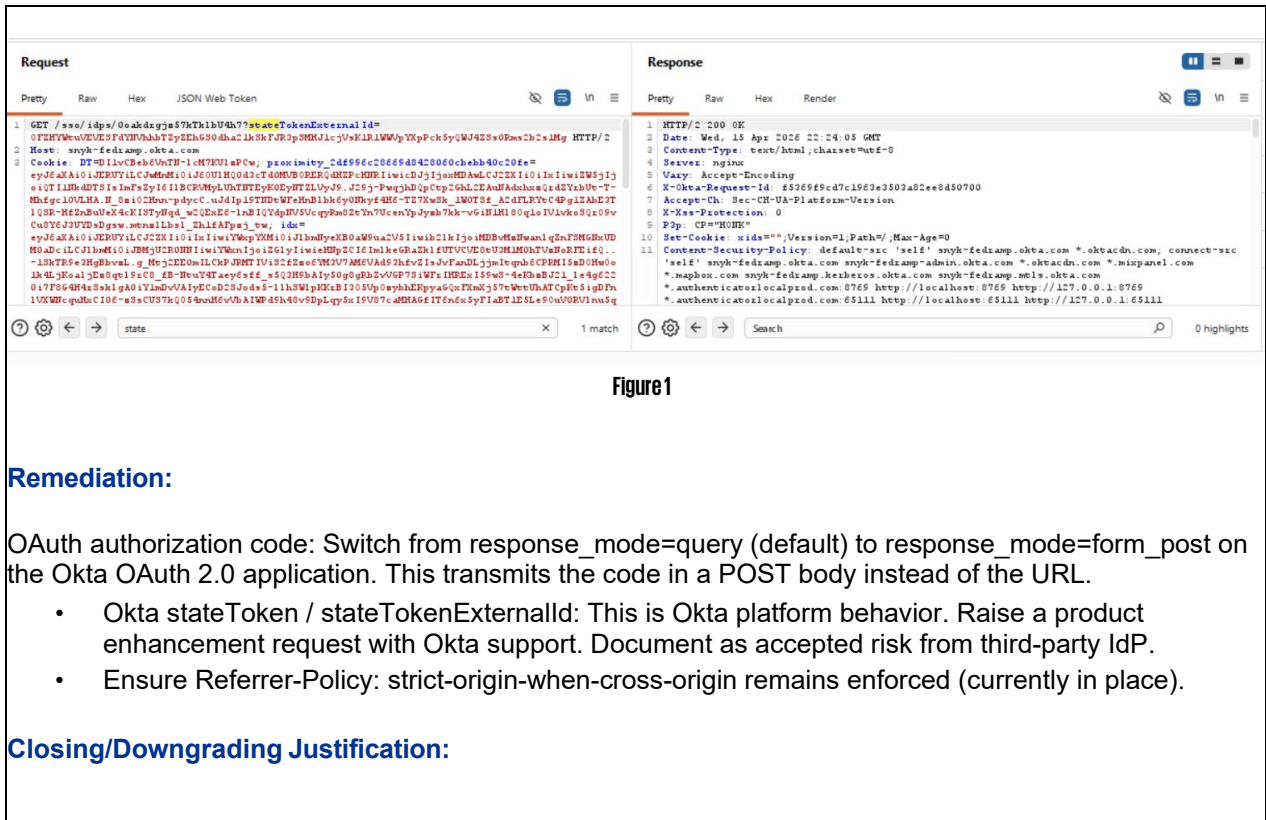
<https://snyk-fedramp.okta.com/sso/idps/>

<https://app.snykgov.io/auth/okta/callback>

Reproduction Steps:

1. Configure Burp Suite to intercept all SSO traffic.
2. Complete a full SSO login flow..
3. Review the Burp HTTP history for requests containing stateToken, stateTokenExternalId, and code parameters in the URL
4. Confirm these sensitive tokens are visible in the browser address bar and would be logged in server access logs.

Screenshots:



Finding 10: HTTP Strict Transport Security (HSTS) Not Submitted to Browser Preload Lists

Informational

Dependency: Application

Status: Open

Description:

The server correctly returns an HSTS header (max-age=31536000; include SubDomains; preload), which satisfies the technical prerequisites for preload list inclusion. However, the domain has not been submitted to the HSTS preload lists maintained by Chrome, Edge, Firefox, or Internet Explorer.

Until the domain is added to these lists, first-time visitors who have never previously connected to the site are not protected by HSTS. An active network attacker positioned before the first connection (e.g., on a public Wi-Fi network) could perform an SSL stripping attack against that initial request.

Affected Systems & Locations:

app.snykgov.io

Reproduction Steps:

1. Visit <https://hstspreload.org> and enter snykgov.io
2. Confirm the eligibility check shows 'Preload list status: Not in preload list'.

Remediation:

- Submit snykgov.io for HSTS preloading at <https://hstspreload.org>
- Ensure the HSTS header remains correctly configured with max-age $\geq$ 31536000, include SubDomains, and preload directives before submission.
- Note that preload list inclusion is permanent — confirm all subdomains fully support HTTPS before submitting.
- Monitor submission status; propagation to all browsers typically takes 2–4 weeks.

Closing/Downgrading Justification:

Finding 11: Sensitive Information Disclosure

Informational

Dependency:

Application/Okta/Microsoft

Status: Open

Description:

Testing identified that multiple servers in the SSO chain return HTTP headers disclosing software versions, build numbers, datacenter regions, and infrastructure architecture:

Server: nginx — Snyk frontend

Server: istio-envoy — Snyk API, reveals Kubernetes + Istio

Server: AmazonS3 — Static assets

Server: Microsoft-HTTPAPI/2.0 — Microsoft Entra ID

Server: 2.1.23906.2 - USGVA ProdSlices — Exact build + US Gov Virginia

Server: 2.1.23906.2 - USGTX ProdSlices — US Gov Texas

Server: 2.1.23906.2 - USGAZLR2 ProdSlices — US Gov Arizona

Via: 1.1 *.cloudfront.net (CloudFront) — CDN node IDs exposed

Affected Systems & Locations:

<https://app.snykgov.io>

<https://snyk-fedramp.okta.com>

<https://login.microsoftonline.us>

Reproduction Steps:

1. Send requests to each host in the SSO chain using Burp Suite or curl.
2. Observe the Server response header on each response.
3. Identify nginx, istio-envoy, AmazonS3, and Microsoft-HTTPAPI/2.0 disclosures.
4. Note the Microsoft login server returns exact build version and datacenter region (e.g., 2.1.23906.2 - USGVA ProdSlices).
5. Check Via headers for CloudFront node identifier disclosure.

Screenshots:

The screenshot displays a network request and its corresponding response in a web browser. The request is a POST to the endpoint `/login/...?redirectUri=...` on the host `app.snykgov.io`. The response is a 200 OK status, indicating a successful login. The response headers are as follows:

- `Server: nginx`
- `X-Request-Id: 2744ec03-47a0-4671-8036-ba471ff5b1b2`
- `Set-Cookie: snyk.id=...`
- `Expires=Wed, 15 Apr 2026 21:29:00 GMT`
- `X-Envoy-Upstream-Service-Time: 30`
- `X-Cache: Miss from cloudfront`
- `Via: 1.1 ffd4d6dfe1b50202a1ef4b159000c76e.cloudfront.net (CloudFront)`
- `X-Auth-Pop: IAD01-P3`
- `X-Auth-Cf-Id: y0UWdEjQis-M9SDJhUdXksSPmoEg-CotPOEgk9a_02RAQ0eY0e20eQ==`
- `X-Xss-Protection: 1; mode=block`
- `X-Frame-Options: SAMEORIGIN`
- `X-Content-Type-Options: nosniff`

Figure 1

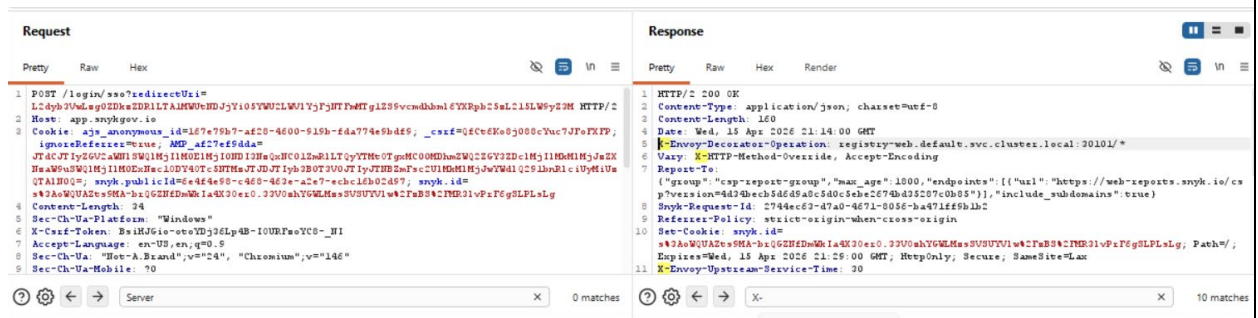


Figure 2

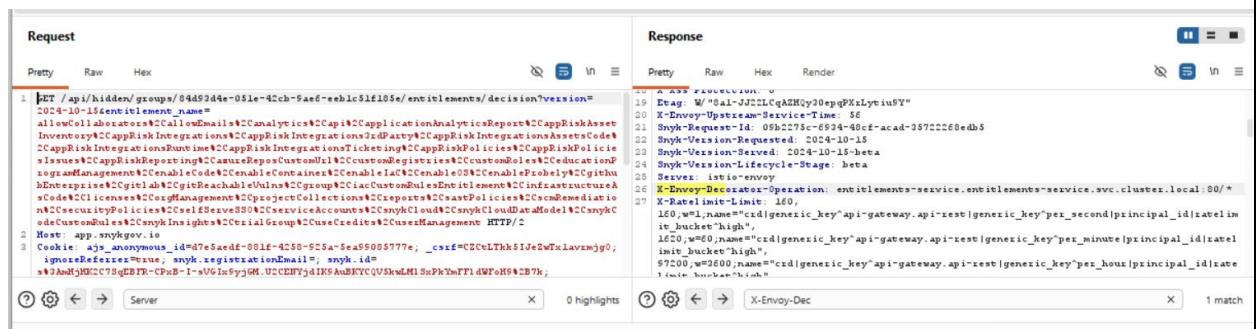


Figure 3

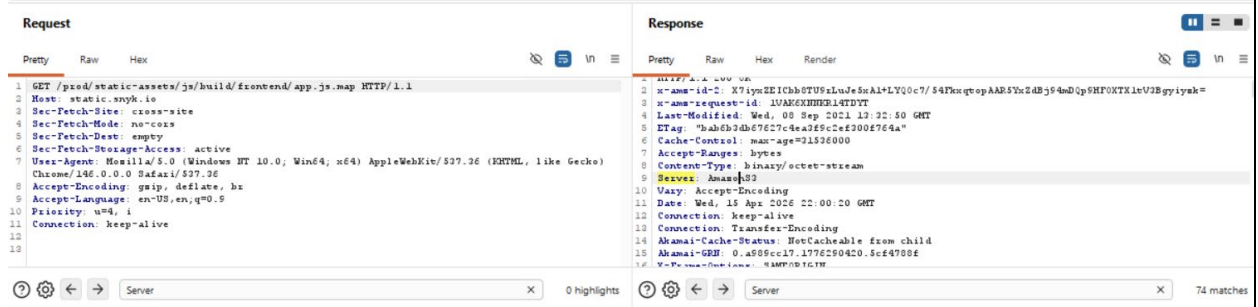


Figure 4

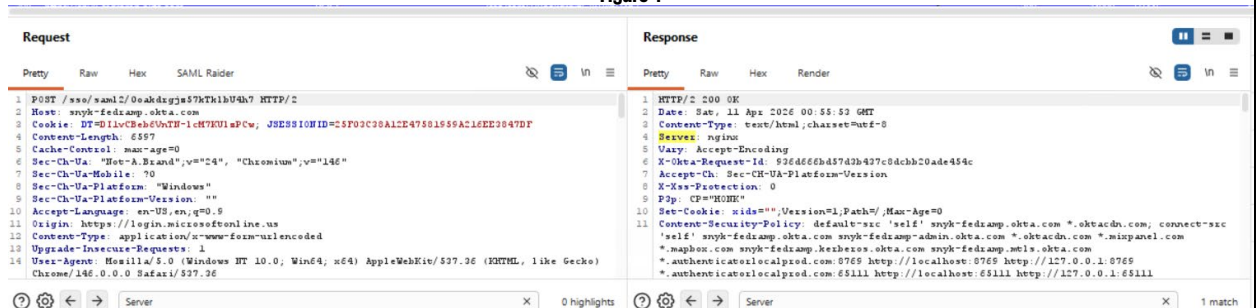


Figure 5

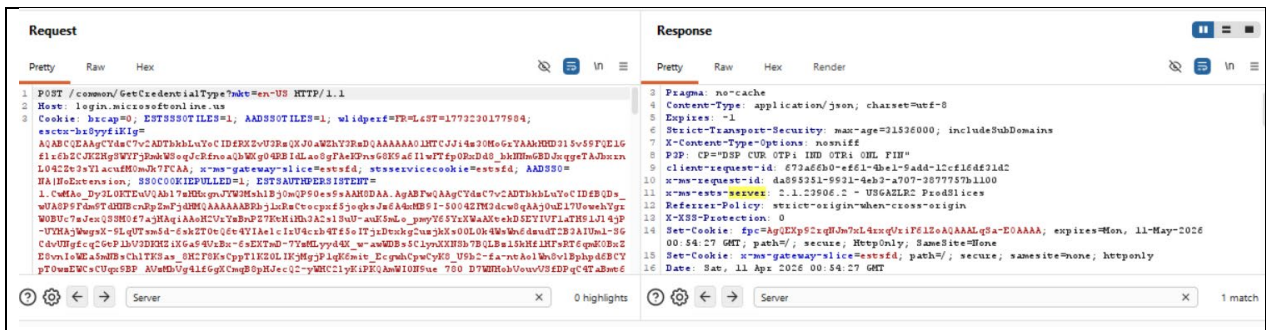


Figure 6

Remediation:

Snyk: Configure nginx with server_tokens off. Configure Istio/Envoy to suppress Server header via EnvoyFilter.

- CloudFront: Consider Lambda@Edge to strip Via header node identifiers.
- Microsoft: The Server header with build/region details is Microsoft platform behavior. Document as accepted risk or raise with Microsoft support for GovCloud.

Closing/Downgrading Justification:

Finding 12: Internal/Hidden API Endpoints Accessible Post-Authentication

Informational

Dependency: Application

Status: Open

Description:

Testing identified that after authentication, the Snyk web application makes requests to `/api/hidden/*` endpoints that expose entitlement decisions, feature flag evaluations, and group enumeration. The "hidden" path prefix suggests internal APIs that may not have the same security review as public endpoints.

Endpoints observed:

`/api/hidden/groups` (with `limit=100`, group enumeration)

`/api/hidden/groups/{id}/entitlements/decision`

`/api/hidden/release_flags/evaluation`

Affected Systems & Locations:

`https://app.snykgov.io/api/hidden/groups`

`https://app.snykgov.io/api/hidden/release_flags/evaluation`

Reproduction Steps:

1. Authenticate to `app.snykgov.io` through the SSO flow
2. Observe network traffic in Burp Suite proxy.
3. Identify GET `/api/hidden/groups?limit=100&sort_by=name&sort_order=ASC` requests
4. Identify POST `/api/hidden/release_flags/evaluation` requests.
5. Confirm these endpoints return data revealing organizational structure and feature flags.

Screenshots:

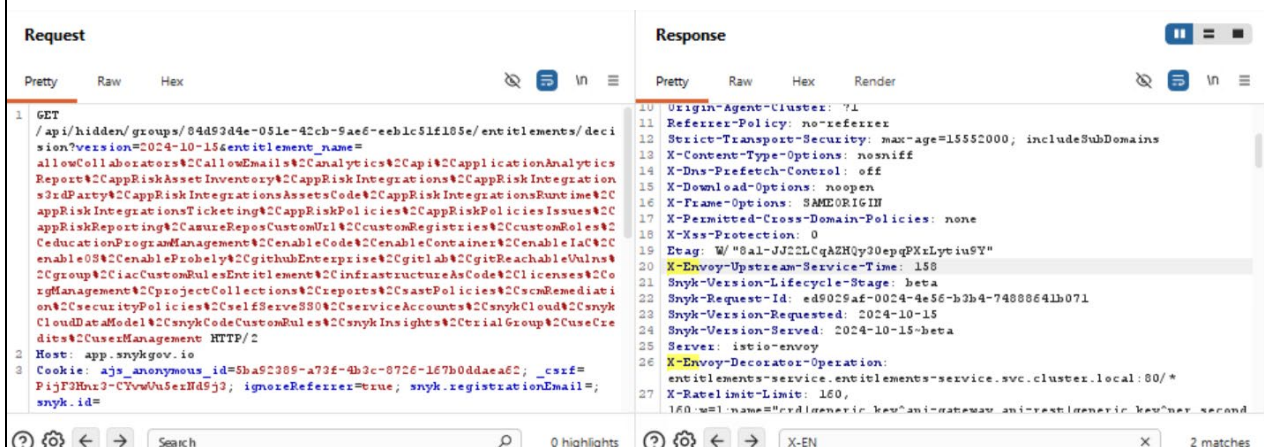


Figure1

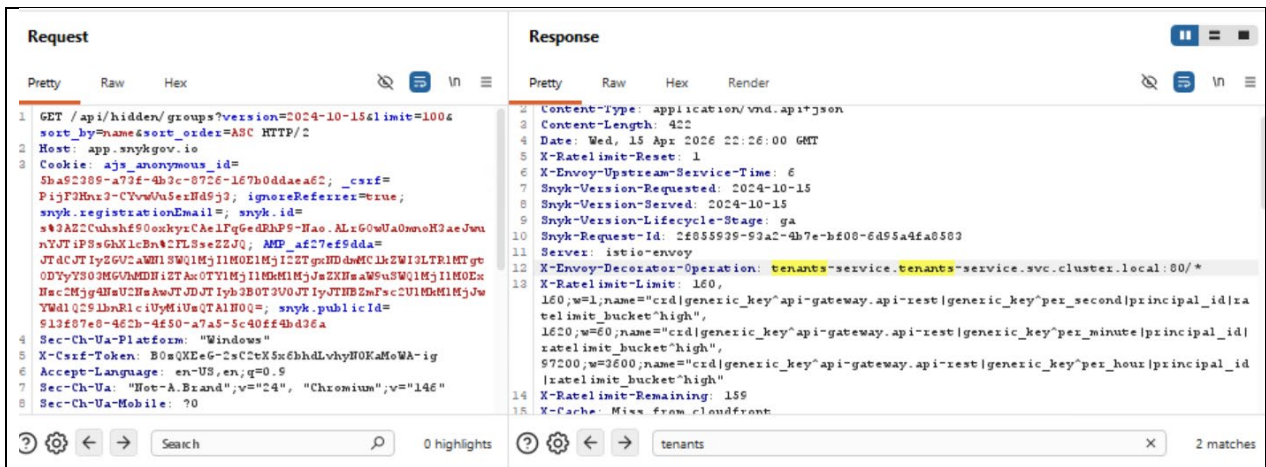


Figure 2

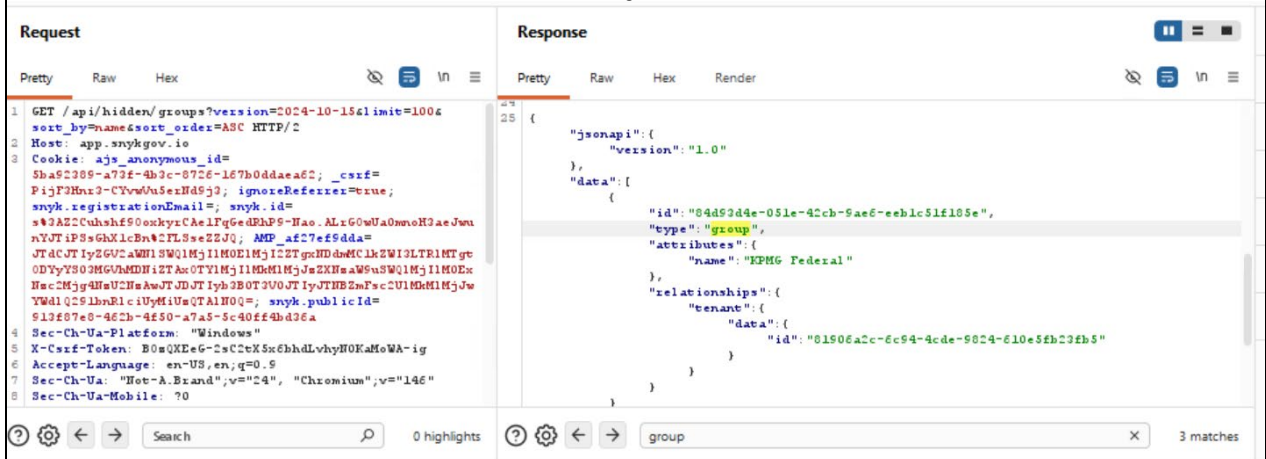


Figure 3

Remediation:

Review authorization controls on /api/hidden/* endpoints.

- Evaluate whether these endpoints should be accessible to browser-based clients.
- Consider renaming the path prefix to avoid signaling internal/undocumented status.

Closing/Downgrading Justification:

Finding 13: RSA 2048-bit Key: Plan Migration to Stronger Algorithm

Informational

Dependency: Application

Status: Open

Description:

The server certificate uses an RSA 2048-bit key with SHA256withRSA signature algorithm. This meets current minimum-security standards and is not immediately vulnerable. However, NIST SP 800-57 guidance indicates RSA 2048-bit keys provide security equivalent to approximately 112-bit symmetric strength, which NIST recommends sunsetting for long-term use cases beyond 2030.

Given the certificate's validity window (Aug 2025 – Sep 2026) and the current infrastructure, no immediate action is required. However, planning for migration to RSA 3072+, ECDSA P-256, or ECDSA P-384 should be incorporated into the next certificate rotation cycle.

Affected Systems & Locations:

app.snykgov.io

Reproduction Steps:

- Cross-reference against NIST SP 800-57 Part 1 Rev 5, Table 2 (symmetric equivalent strength by algorithm and key length).

Remediation:

- Plan migration to ECDSA P-256 or ECDSA P-384 on next certificate renewal for improved security and reduced handshake overhead.
- If RSA is required for compatibility, upgrade to RSA 3072 or 4096 bits.
- Verify that Amazon Certificate Manager (the current issuer) supports the target algorithm before scheduling rotation.
- Update any automation or pinning configurations that reference the current RSA key.

Closing/Downgrading Justification:

Finding 14: SSL Certificate Expiry in Approximately 4.5 Months

Informational

Dependency: Application

Status: Open

Description:

The primary TLS certificate for snykgov.io is valid until Fri, 04 Sep 2026 23:59:59 UTC — approximately 4 months and 19 days from the date of this assessment. While this does not represent an immediate concern, it should be tracked to ensure automated renewal is functioning correctly and that no manual intervention will be required.

The certificate is issued by Amazon Certificate Manager (ACM). ACM typically handles automated renewal for certificates attached to AWS services (CloudFront in this case). If renewal automation were to fail silently, an expired certificate would result in browser trust errors for all users.

Affected Systems & Locations:

app.snykgov.io

Reproduction Steps:

- Check the after using command .
echo | openssl s_client -connect app.snykgov.io:443 -servername app.snykgov.io 2>/dev/null | openssl x509 -noout -text | grep -A2 "Validity\|Issuer\|Subject:"

Remediation:

- Verify that ACM automatic renewal is enabled and the certificate is in 'Pending renewal' or 'Issued' status with a future expiry.
- Confirm CloudFront distribution is associated with the ACM certificate and will receive the renewed certificate automatically.

Closing/Downgrading Justification:

Finding 15: Concurrent User Session

Informational

Dependency: Application

Status: Open

Description:

: During the Single Sign-On (SSO) configuration review and testing of the application authentication flow, it was observed that the application allows multiple concurrent sessions for the same user account from different browsers and client IP addresses. During testing, the same user account was able to authenticate successfully from multiple browser sessions simultaneously without invalidating the previously established session. Both sessions remained active and were able to access the application at the same time.

Allowing concurrent sessions is typically a design decision depending on the organization's security policy. However, in certain environments where sensitive data is handled, limiting concurrent sessions or notifying users of simultaneous logins can help reduce risks associated with session misuse, credentials sharing, or unauthorized access.

If organizations require stricter session management controls, mechanisms should be implemented to detect and manage concurrent sessions appropriately.

Affected Systems & Locations:

<https://snyk-fedramp.okta.com/login/cert>

Reproduction Steps:

- Configure Burp Suite to intercept traffic to app.snykgov.io
- Complete a full SSO login – capture Session 1 snyk.id.cookie.
- Without logging out, open a second browser/private window and complete another SSO login – capture Session 2.

Screenshots:

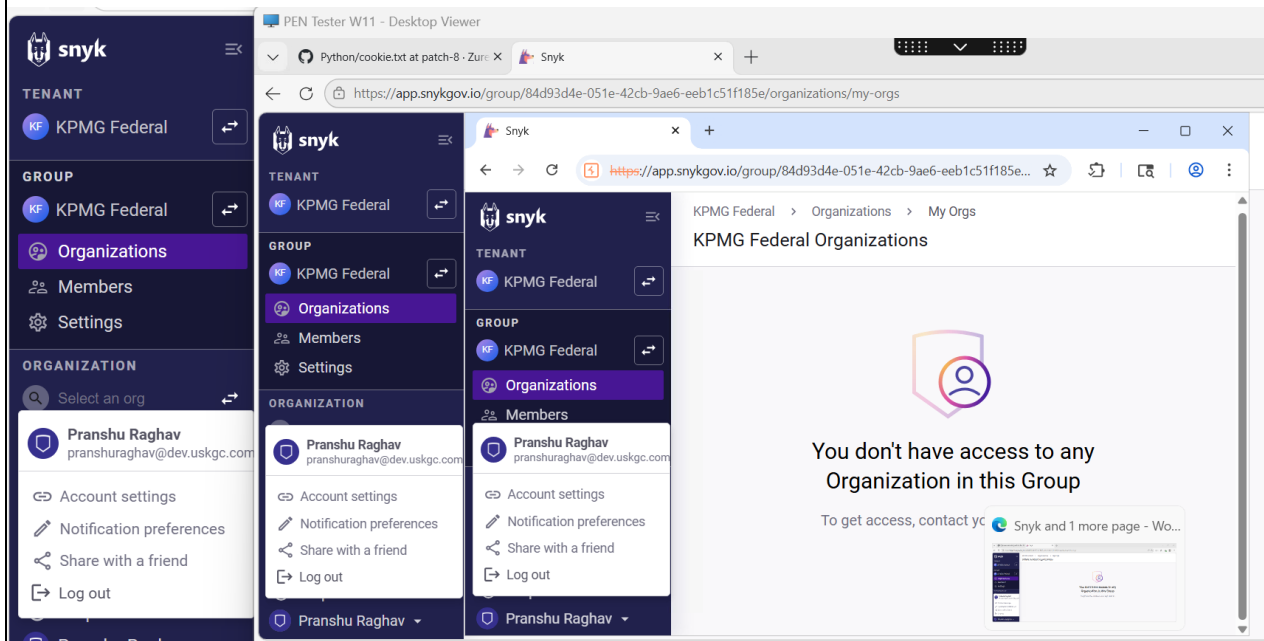


Figure 1

Remediation:

- It Okta Admin console under global session policy configure the number of maximum concurrent session per user – set to 1 to force single session.
- Action on new login – either terminate the oldest session or prompt the user
- Snyk should invalidate all existing sessions for a user upon a new successful authentication. This is a standard session management – on login success, the server queries all active sessions for that publicID and marks them expired before issuing the new one.

Closing/Downgrading Justification:

Appendix

Risk Rating Criteria

Overall Risk Rating Matrix					
Likelihood	Impact				
	Negligible	Minor	Moderate	Significant	Severe
Very High	Low	Medium	High	High	Very High
High	Low	Medium	Medium	High	High
Medium	Low	Low	Medium	Medium	High
Low	Low	Low	Low	Medium	Medium
Very Low	Informational	Low	Low	Low	Low

Likelihood * Impact Risk Rating	
Risk Rating	Value
Very High	25
High	15-20
Medium	7-14
Low	1-6
Informational	1

Risk Rating is determined by multiplying Impact * Likelihood

Examples:

Likelihood Low (2) * Impact Moderate (3) = 6 (Low)

Likelihood High (4) * Impact Moderate (3) = 12 (Medium)

Likelihood Very High (5) * Impact Severe (5) = 25 (Very High)

Impact Rating Guidance	
Severe	Typically reserved for compromise (e.g. data exfiltration, ransomware) of DC3-type datasets, passwords/credentials with access to significant resources, or complete takeover of a system which has significant impacts to KPMG for lateral-based movement/attacks and disruption to the business (e.g. RP0/RP1-rated systems such as Active Directory).
Significant	Typically reserved for compromise (e.g. data exfiltration, ransomware) of DC3-type datasets, passwords/credentials with access to significant resources, or complete takeover of a system which has significant impacts to KPMG for lateral-based movement/attacks and disruption to the business.
Moderate	Typically reserved for compromise (e.g. data exfiltration, ransomware) of DC2-type datasets or partial takeover of a system which has moderate impacts to the business (e.g. RP2-rated systems such as a Business Application).
Minor	Typically reserved for compromise (e.g. data exfiltration, ransomware) of low-risk datasets such as DC1 or partial takeover of a system which has low impact of disruption to the business (e.g. RP3/4-rated systems).
Negligible	Reserved to document findings which have no material impact to KPMG or the Business.

Terminology

Depending on likelihood and impact, the findings will be assigned to one of the following risk ratings:

Very High

Very high risk findings represent a severe weakness that can be easily exploited by an adversary, leading to a direct and immediate impact on the business. This could include a full system compromise, significant data exfiltration, or a widespread denial-of-service condition. Such vulnerabilities pose the highest level of security risk.

Immediate action is required. For systems not yet in production, remediation must be completed before the "go-live" date. For production systems, remediation must be completed within five (5) days of the preliminary report date.

High

A high risk finding indicates a significant weakness that, if exploited, could result in substantial damage to business assets or reputation. Exploitation may require more specific conditions or attacker skill than a critical finding but still presents a high degree of security risk.

For systems not yet in production, remediation must be completed before the "go-live" date. For production systems, remediation must be completed within thirty (30) days of the preliminary report date.

Medium

A medium risk finding points to a moderate security weakness. While it may not lead to a full system compromise on its own, it could be leveraged by an attacker in conjunction with other vulnerabilities to achieve a greater impact or could result in minor data leakage or service degradation.

For systems not yet in production, remediation should be completed before the "go-live" date. For production systems, remediation must be completed within sixty (60) days of the preliminary report date.

Low

A low risk finding identifies a minor security weakness that has a limited potential for impact. Exploiting such a flaw is often difficult or would result in minimal damage. These findings typically represent a minor security risk but should be addressed to maintain a strong security posture.

Remediation for low-risk findings is recommended to be included in the next scheduled product update or maintenance cycle.

Informational

An informational finding is an observation that does not represent an immediately exploitable vulnerability but highlights a deviation from security best practices, a configuration weakness, or unusual system behavior that could pose a risk in the future.

No formal Remediation SLA is defined for informational findings. These are provided for consideration to improve overall security hygiene.

Methodology

Our security assessment follows a structured methodology designed to provide comprehensive and rigorous testing, from initial discovery to final reporting.

Reconnaissance and Discovery

The engagement begins with defining the external attack surface. We conduct reconnaissance to map the client's internet-facing infrastructure, using a combination of public sources and specialized tools. The objective is to identify all associated IP blocks, hostnames, domains, and subdomains. This process reveals the full scope of potential targets and informs the subsequent stages of the assessment.

Threat Modeling and Analysis

Following discovery, each in-scope application is analyzed to create a comprehensive threat model. We map critical information flows, business logic, user roles, architectural dependencies (e.g., web servers, APIs, databases), and third-party components. This analysis allows us to identify likely threat actors, define key attack vectors, and prioritize testing efforts based on the application's unique risk profile.

Application Enumeration and Profiling

With the attack surface defined, we actively enumerate the target applications to build a detailed service and functionality profile. Using a variety of tools and manual techniques, we gather in-depth information about the application's structure, technologies, and exposed resources. This intelligence gathering is crucial for identifying specific modules, functions, and configurations that will be targeted during vulnerability testing.

Vulnerability and Security Control Analysis

This is the core testing stage where we execute a comprehensive vulnerability assessment to identify security weaknesses. Our methodology is guided by industry-standard frameworks, including the OWASP Top 10, CWE Top 25, and MITRE ATT&CK®. We employ a combination of automated scanning and rigorous manual testing to evaluate the effectiveness of existing security controls across several key categories:

- Information Gathering
- Configuration and Deployment Management
- Authentication and Authorization
- Session Management
- Input Validation and Sanitization
- Cryptography and Data Protection

This hybrid approach ensures we identify both known vulnerabilities and complex, logic-based flaws that automated tools often miss.

Exploitation and Impact Validation

This activity validates the real-world impact of vulnerabilities identified during the assessment. We perform controlled exploitation of discovered weaknesses to determine the severity and potential business impact. By simulating adversarial tactics, we demonstrate how an attacker could compromise the application, escalate privileges, or access sensitive data, providing clear evidence of the risk.

Mitigation and Remediation Strategy

Based on the findings from the engagement, we develop a comprehensive mitigation plan. This includes providing tactical recommendations for addressing each specific vulnerability, as well as strategic guidance on secure development practices to enhance the overall security posture of the application.

Reporting

The final activity involves documenting all observations, findings, and recommendations in a formal report. Each vulnerability is assigned a risk rating based on the Common Vulnerability Scoring System (CVSS v3.1) and mapped to relevant CWE identifiers. The report delivers a clear, actionable summary for stakeholders and detailed technical analysis for engineering teams.

DSG Disclaimer Notice

Cybersecurity threats are continually changing, with new vulnerabilities discovered on a daily basis, and no application can ever be 100% secure no matter how much security testing is conducted. This report cannot and does not protect against personal or business loss as the result of use of the applications or systems described. DSG offers no warranties, representations or legal certifications concerning the applications or systems it tests.

All software includes defects: nothing in this document is intended to represent or warrant that security testing was complete and without error, nor does this document represent or warrant that the application tested is suitable to task, free of other defects than reported, fully compliant with any industry standards, or fully compatible with any operating system, hardware, or other application. By using this reported information, you agree that DSG shall be held harmless in any event.

Non-Production and Production Testing Advisory

It is important for the customer to understand that the engagement testing in non-production environments such as UAT (User Acceptance Testing) or QC (Quality Control) represents what is found only in such environments. If there are inaccuracies, omissions, or changes made during or after the testing engagement; this may impact findings visibility and ultimately the accuracy of this report. It is equally important to note that UAT and QC environments should ultimately mimic the production environment. DSG pen testers, unless at the request of the customer, do not typically perform testing within a production environment for general stability and safety concerns. If production testing is a requirement by the SRM (Security Relationship Manager), please create a separate PTI (Penetration Testing Intake) form for as such and notify the DSG pen testers.

Modifications during Testing Engagements

If the customer performs any modifications or changes to the testing environment during an engagement, this may adversely impact the accuracy of the report and findings. Customers should be prepared to freeze changes where possible. If it is not possible, please notify the DSG pen testers of the intended change, time of change, and to which assets it will affect.

Contact us

Digital Security Group

Adversarial Testing

US-DLBPGAdversarialTestingAll@kpmg.com

Learn about us:



kpmg.com